

Tool

Tool - Jianjun Chen, GitHub.

- Published: date not stated
- Original: <<https://github.com/chenjj/espoofer>>
- Preserved from: <https://github.com/chenjj/espoofer> (git) on 2026-08-09
- Repository commit: 60e5ed00f352999abb485bf12e8fdb2d83ddeb0
- Licence: see the repository

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

This reference is a source-code repository. The archive preserves its documentation at an exact commit; the code itself stays in a private mirror and is never checked out, built or run.

- Repository: <<https://github.com/chenjj/espoofer>>
- Commit: 60e5ed00f352999abb485bf12e8fdb2d83ddeb0
- Documents preserved: 2

LICENSE

Blob 721def887636, 1069 bytes, at commit 60e5ed00f352.

MIT License

Copyright (c) 2019 Jianjun Chen

Permission is hereby granted, free of charge, to any person obtaining a copy of this software and associated documentation files (the "Software"), to deal in the Software without restriction, including without limitation the rights to use, copy, modify, merge, publish, distribute, sublicense, and/or sell copies of the Software, and to permit persons to whom the Software is furnished to do so, subject to the following conditions:

The above copyright notice and this permission notice shall be included in all copies or substantial portions of the Software.

THE SOFTWARE IS PROVIDED "AS IS", WITHOUT WARRANTY OF ANY KIND, EXPRESS OR IMPLIED, INCLUDING BUT NOT LIMITED TO THE WARRANTIES OF MERCHANTABILITY, FITNESS FOR A PARTICULAR PURPOSE AND NONINFRINGEMENT. IN NO EVENT SHALL THE AUTHORS OR COPYRIGHT HOLDERS BE LIABLE FOR ANY CLAIM, DAMAGES OR OTHER LIABILITY, WHETHER IN AN

ACTION OF CONTRACT, TORT OR OTHERWISE, ARISING FROM, OUT OF OR IN CONNECTION WITH THE SOFTWARE OR THE USE OR OTHER DEALINGS IN THE SOFTWARE.

README.md

Blob `fa39cb4b9ff1` , 9452 bytes, at commit `60e5ed00f352` .

espoofeer

espoofeer is an open-source testing tool to bypass SPF, DKIM, and DMARC authentication in email systems. It helps mail server administrators and penetration testers to check whether the target email server and client are vulnerable to email spoofing attacks or can be abused to send spoofing emails.

<!-- [image: Gmail spoofing demo] --> <p align="center"> <code> </code>
Figure 1. A case of our spoofing attacks on Gmail (Fixed, Demo video) </p>

Why build this tool?

Email spoofing is a big threat to both individuals and organizations ([Yahoo breach](#), [John Podesta](#)). To address this problem, modern email services and websites employ authentication protocols -- SPF, DKIM, and DMARC -- to prevent email forgery.

Our latest research shows that the implementation of those protocols suffers a number of security issues, which can be exploited to bypass SPF/DKIM/DMARC protections. Figure 1 demonstrates one of our spoofing attacks to bypass DKIM and DMARC in Gmail. For more technical details, please see our [Black Hat USA 2020 talk](#) (with [presentation video](#)) or [USENIX security 2020 paper](#).

- Black Hat USA 2020 slides (PDF): [You have No Idea Who Sent that Email: 18 Attacks on Email Sender Authentication](#)
- USENIX security 2020 paper (PDF): [Composition Kills:

A Case Study of Email Sender Authentication](https://www.usenix.org/system/files/sec20fall_chen-jianjun_prepub_0.pdf)

- [Distinguished Paper Award Winner](#)

In this repo, we summarize all test cases we found and integrate them into this tool to help administrators and security-practitioners quickly identify and locate such security issues.

<details><summary>Please use the following citation if you do scientific research (Click me).</summary> <p>

Latex version:

```
@inproceedings{chen-email,
author = {Jianjun Chen and Vern Paxson and Jian Jiang},
title = {Composition Kills: A Case Study of Email Sender Authentication},
booktitle = {29th {USENIX} Security Symposium ({USENIX} Security 20)},
year = {2020},
isbn = {978-1-939133-17-5},
pages = {2183--2199},
url = {https://www.usenix.org/conference/usenixsecurity20/presentation/chen-jianjun},
publisher = {{USENIX} Association},
month = aug,
}
```

Word version:

Jianjun Chen, Vern Paxson, and Jian Jiang. "Composition kills: A case study of email sender authentication." In 29th USENIX Security Symposium (USENIX Security 20), pp. 2183-2199. 2020.

</p> </details>

Installation

- Download this tool

```
git clone https://github.com/chenjj/espoofer
```

- Install dependencies

```
sudo pip3 install -r requirements.txt
```

Python version: Python 3 (>=3.7).

Usage

espoofer has three work modes: *server* ('s', default mode), *client* ('c') and *manual* ('m'). In *server* mode, espoofer works like a mail server to test validation in receiving services. In *client* mode, espoofer works as an email client to test validation in sending services. *Manual* mode is used for debug purposes.

<p align="center">
 Figure 2. Three types of attackers and their work modes </p>

Server mode

To run espoofer in server mode, you need to have: 1) an IP address (1.2.3.4), which outgoing port 25 is not blocked by the ISP, and 2) a domain (attack.com).

1. Domain configuration

- Set DKIM public key for `attack.com`

```
selector._domainkey.attacker.com TXT "v=DKIM1; k=rsa; t=y; p=MIGfMA0GCSqGSIb3DQEBAQUAA4GNADCBiQKBgQDN
```

- Set SPF record for `attack.com`

```
attack.com TXT "v=spf1 ip4:1.2.3.4 +all"
```

1. Configure the tool in config.py

```
config={
    "attacker_site": b"attack.com", # attack.com
    "legitimate_site_address": b"admin@bank.com", # legitimate.com
    "victim_address": b"victim@victim.com", # victim@victim.com
    "case_id": b"server_a1", # server_a1
}
```

You can list find the case_id of all test cases using `-l` option:

```
python3 espoofer.py -l
```

1. Run the tool to send a spoofing email

```
python3 espoofer.py
```

You can change case_id in the config.py or use `-id` option in the command line to test different cases:

```
python3 espoofer.py -id server_a1
```

Client mode

To run espoofer in client mode, you need to have an account on the target email services. This attack exploits the failure of some email services to perform sufficient validation of emails received from local MUAs. For example, `attacker@gmail.com` tries to impersonate `admin@gmail.com`.

1. Configure the tool in config.py

```

config={
    "legitimate_site_address": b"admin@gmail.com",
    "victim_address": b"victim@victim.com",
    "case_id": b"client_a1",

    "client_mode": {
        "sending_server": ("smtp.gmail.com", 587), # SMTP sending serve ip and port
        "username": b"attacker@gmail.com", # Your account username and password
        "password": b"your_password_here",
    },
}

```

You can list find the case_id of all test cases using `-l` option:

```
python3 espoofer.py -l
```

Note: `sending_server` should be the SMTP sending server address, not the receiving server address.

1. Run the tool to send a spoofing email

```
python3 espoofer.py -m c
```

You can change case_id in the config.py and run it again, or you can use `-id` option in the command line:

```
python3 espoofer.py -m c -id client_a1
```

Manual mode

Here is an example of manual mode:

```
python3 espoofer.py -m m -helo attack.com -mfrom <m@attack.com> -rcptto <victim@victim.com> -data raw_msg_her
```

Screenshots

1. A brief overview of test cases.

`<p align="center"> <kbd>  </kbd> </p>`

Bugs found with this tool

- Gmail.com DMARC bypass demo video, <https://youtu.be/xuKZpT0rsd0>

- Outlook.com DMARC bypass video, <https://youtu.be/IsWgAEbPaK0>
- Yahoo.com DMARC bypass video, <https://youtu.be/DRepfStOruE>
- Protonmail.com DMARC bypass video, https://youtu.be/bh4_SoPniMA
- CVE-2020-12272, OpenDMARC bypass bug report, <https://sourceforge.net/p/opendmarc/tickets/237/>
- CVE-2019-20790, OpenDMARC and pypolicyd-spf bypass bug report, <https://sourceforge.net/p/opendmarc/tickets/235/>
- Mail.ru DMARC bypass bug report on HackerOne, <https://hackerone.com/reports/731878>

Welcome to send a pull request to file your bug report here.

Q&A

1. How do I know if the email has bypassed DMARC authentication successfully?

You can check it in the Authentication-results header in the raw message headers. If the header shows `dmARC=pass`, it means the email has passed the DMARC authentication. You can check some demos video [here](#).

1. Why do emails fail to send?

There are several possible reasons if you fail to send an email: 1) your ISP blocks outgoing emails to port 25 to prevent spam. In this case, you need to ask for permission from the ISP; 2) the IP address is in the spam list of the target email services. In many cases, you resolve the problem here, <https://www.spamhaus.org/lookup/>; 3) some email services check if there is a PTR record for the sending IP, you may also need to set the PTR record to bypass this check; 4) the email cannot pass the format validation of the target email service, you may want to try a different test case.

1. Why the email goes to the spam folder? Any way to avoid this?

Currently, espoofer focuses on bypassing SPF/DKIM/DMARC authentication and doesn't aim for spam filter bypass. But you could try to use a reputable sending IP address, domain, and benign message content to bypass the spam filter.

1. Why I send an email successfully but the email didn't show up in either inbox or spam folder?

In our prior experiences, some email services filter suspicious emails silently.

1. When testing server_a5/a6, why I cannot set special characters like "(" in the domain?

You will need to set up your own authority DNS server, rather than use third-party DNS hosting services, as some DNS hosting services have restrictions on setting special characters. See [issue](#).

Credits

Welcome to add more test cases.

<!-- This repo is created for the vendors to reproduce our reported issues, so this tool is not useable without additional instructions. We will update it after the affected vendors have fixed our reported bugs. -->

